

Care Access Navigator

Risk Management Rubric — Criterion 1: Risk Management Fundamentals

1.1 Framework Selection and Justification

Care Access Navigator adopts the **NIST Risk Management Framework (RMF)** as its primary risk management methodology, rather than ISO 31000. This choice keeps the Risk Management course deliverables aligned with the capstone's own Week 9 milestone, which maps controls to HIPAA Security Rule concepts and NIST framework/control concepts. Using one framework across both the risk assessment work (Week 8) and the compliance mapping work (Week 9) avoids maintaining two separate risk vocabularies for the same project.

1.2 Core Risk Terminology, Applied to Care Access Navigator

Each term below is defined in the standard sense and then grounded in a real element of the project, so the framework reads as applied analysis rather than restated theory.

Term	Textbook Meaning	Applied to Care Access Navigator
Asset	Something with value worth protecting	EHR Simulator (holds synthetic ePHI); Patient Portal; Billing App; HR App; Keycloak IdP; the 7 RBAC roles themselves (Clinician, Nurse, Billing, HR, IT Support, Security Analyst, Vendor); the GRC evidence index/store
Threat	A source of potential harm	External attacker attempting credential stuffing/brute force against Keycloak; malicious or careless insider with legitimate access (e.g., a Billing-role user viewing more ePHI than their job requires); third-party/vendor whose access outlives their contract; environmental/operational event (e.g., data loss from an unbacked-up evidence store)
Vulnerability	A specific, exploitable weakness	MFA not yet enforced for Keycloak admin/privileged accounts; no automated deprovisioning trigger tied to a vendor's contract end date; RBAC role definitions broader than the job actually requires (e.g., Billing role); periodic access review has no automated reminder/enforcement, allowing stale access to accumulate for a full quarter unnoticed
Control	The safeguard that addresses a vulnerability	MFA + mTLS enforced at Keycloak for privileged accounts (NIST IA-2(1)); TLS 1.2/1.3 terminating at the reverse proxy/WAF in the DMZ VLAN; internal segmentation firewall enforcing 802.1X + inter-VLAN ACLs; joiner-mover-leaver (JML) workflow with automated deprovisioning tied to HR/vendor contract data; quarterly periodic access review process with documented remediation actions

Note the pairing across rows: each Vulnerability example lines up with the Control that specifically addresses it (e.g., the Keycloak MFA gap pairs with MFA+mTLS enforcement), and these same four vulnerabilities are the basis for risks R-01, R-02, R-03, and R-08 in the project's risk register — so this table and the register tell one consistent story.

1.3 Governance Structure

Roles and decision authority reuse the stakeholders already named in the Project Design Documentation, organized into a clear chain of responsibility and escalation.

Role	Responsibility	Decision Authority
IAM Analyst	Implements access controls and RBAC changes	Day-to-day access provisioning and role configuration
Security Analyst	Monitors systems, investigates incidents	Alert triage and incident investigation
GRC Analyst	Owens the risk register, control matrix, and evidence	Validates risk scoring and control mapping
Department Manager	Approves access requests for their team	Accepts residual risk for their own department
HR / Workforce Administrator	Triggers joiner-mover-leaver events	Supplies the data JML automation depends on
Program Sponsor	Final authority on unresolved High risk	Formally accepts any risk that remains High after treatment

Escalation path: an analyst identifies and scores a risk → the GRC Analyst validates the scoring and control mapping → the Department Manager approves the treatment plan → any risk that remains rated High even after treatment escalates to the Program Sponsor, who must formally accept that residual risk on the record rather than let it sit unaddressed.

1.4 Regulatory Compliance Matrix — HIPAA Security Rule

HIPAA is used as the one required industry framework, since ePHI protection is already Care Access Navigator's stated regulatory context. Each safeguard category is mapped to a specific citation, the corresponding NIST CSF function, and the actual project control or evidence that addresses it.

Safeguard	HIPAA Requirement	NIST CSF Function	CAN Control / Evidence	Status
Administrative	Security Management Process — 164.308(a)(1)	Identify (Risk Assessment)	Risk register, risk methodology documentation	In Progress
Administrative	Workforce Security — 164.308(a)(3)	Protect (Identity Mgmt / Access Control)	RBAC matrix, JML workflows, access-request/approval process	In Progress
Administrative	Information Access Management — 164.308(a)(4)	Protect (Access Control)	Least-privilege role design, periodic access review	Not Started
Administrative	Security Incident Procedures — 164.308(a)(6)	Respond (Incident Response)	SIEM detection use cases, incident investigation runbook	Not Applicable
Administrative	Contingency Plan — 164.308(a)(7)	Recover (Recovery Planning)	Business Impact Analysis (RTO/RPO/MTD per asset)	In Progress
Physical	Facility Access Controls — 164.310(a)(1)	Protect (Physical Access)	Not applicable — simulated/cloud lab environment	Not Applicable
Technical	Access Control — 164.312(a)(1)	Protect (Access Control)	Keycloak RBAC, unique user IDs, automatic logoff policy	In Progress
Technical	Audit Controls — 164.312(b)	Detect (Security Monitoring)	SIEM log collection, authentication/audit trail	In Progress

Safeguard	HIPAA Requirement	NIST CSF Function	CAN Control / Evidence	Status
Technical	Person or Entity Authentication — 164.312(d)	Protect (Identity Mgmt)	MFA policy at Keycloak for privileged/admin accounts	In Progress
Technical	Transmission Security — 164.312(e)(1)	Protect (Data Security)	TLS 1.2/1.3 at Keycloak, reverse proxy/WAF in DMZ	Done

This matrix is the same one maintained live in the project's Compliance_Matrix workbook tab — the Status column should be updated there as each control is genuinely implemented, so this printed table stays a point-in-time snapshot rather than the only copy.

1.5 Visual Framework Mapping

The diagram below maps each of the six NIST RMF steps (left, navy) to where that step concretely happens in Care Access Navigator (right, light blue). The dashed red line from Monitor back to Categorize reflects that RMF is a continuous cycle, not a one-time checklist: findings from ongoing monitoring feed back into re-categorizing assets and risks.

NIST RMF -> Care Access Navigator Mapping

